COMPREHENSIVE PENETRATION TESTING REPORT & CAPSTONE

Vulnerability Assessment & Penetration Testing (VAPT)

Prepared for: Executive Committee / System Owner
Prepared by: Security Assessment Team (Capstone Sample)
Document date: 10 October 2026

CONFIDENTIAL — CONTROLLED DISTRIBUTION

This is an educational sample report. All assets, observations, scores, and findings are illustrative placeholders. It is not evidence of testing against a real organization or system.

Version 1.0 | Classification: Sample / Training | Review status: Draft

1. Document Control & Confidentiality

Field	Value
Document title	Comprehensive Penetration Testing Report & Capstone
Version	1.0
Assessment type	Illustrative VAPT capstone
Report owner	Security Assessment Team
Intended audience	Executive Committee, Engineering, IT Operations, Risk
Classification	Sample / Training
Review status	Draft — requires asset-owner validation

Confidentiality

A real VAPT report may contain sensitive architecture details, exploitable weaknesses, identifiers, and evidence. Distribute it only to named recipients with a business need. Store it in approved access-controlled repositories, encrypt it in transit and at rest, and follow the organization's retention schedule.

Use restrictions

Do not treat this sample as an attestation, certification, or representation that a live penetration test was performed. Replace every placeholder with verified engagement information before issuing a real report.

Revision history

Version	Date	Change	Author
1.0	10 Oct 2026	Initial educational capstone sample	Security Assessment Team

2. Executive Summary

This report demonstrates how an enterprise VAPT deliverable can communicate security observations, technical context, business impact, and prioritized remediation to decision-makers. The example dataset contains three illustrative findings: one High, one Medium, and one Low. No live target was tested to produce this sample.

Severity	Illustrative count	Response expectation
Critical	0	Immediate escalation; containment and leadership decision
High	1	Owner assigned promptly; target remediation within 7 days
Medium	1	Planned remediation; target within 14 days
Low	1	Address through normal engineering cycle; target within 30 days
Informational	0	Track where it improves resilience

Executive interpretation

The highest-priority example concerns insufficient login throttling. If verified in a real environment and not mitigated elsewhere, this can increase exposure to repeated authentication abuse. The sample also illustrates missing browser security headers and verbose error responses. These are common hardening themes, but their actual risk depends on deployment context, exploitability, business criticality, and compensating controls.

Recommended decisions

• Assign a named owner and due date to every confirmed finding.

• Prioritize authentication protections and monitoring before lower-impact hardening tasks.

• Require evidence-based retesting before closure.

• Use formal risk acceptance with an approver and expiry when remediation is deferred.

3. Engagement Objectives & Scope

Objectives

• Identify and validate security weaknesses within an explicitly authorized scope.

• Estimate technical severity using CVSS v3.1 and classify findings with relevant OWASP categories.

• Explain business impact in terms of confidentiality, integrity, availability, and operational risk.

• Provide actionable remediation steps and retest criteria.

• Deliver a traceable evidence register and management-ready risk summary.

Illustrative scope

Scope item	Sample value
Application	app.example.test (placeholder only)
Interfaces	Web login and illustrative API
Environment	Training dataset only; no live assessment
Test accounts	None used; examples are hypothetical
Testing window	Not applicable — sample report
Exclusions	All real/public systems; production targets; third-party assets

For a real engagement, list exact hostnames, IP ranges, application paths, API endpoints, environments, test identities, and approved source addresses. Scope must be approved in writing before testing begins.

This sample uses placeholder domains and example observations so the structure can be studied safely without implying authorization or access to any external target.

4. Authorization & Rules of Engagement

Testing must begin only after the asset owner provides written authorization. The rules of engagement define what is allowed, when testing may occur, who can be contacted, and how evidence must be handled.

Minimum authorization record

• Approver, business purpose, and approval reference.

• Exact assets and environments in scope, with exclusions.

• Approved testing dates, time zone, rate limits, and source IPs.

• Allowed techniques and prohibited actions.

• Test accounts, test data, and data-handling rules.

• Emergency contact and stop conditions.

• Reporting recipients, classification, retention, and disclosure rules.

Stop conditions

Immediately pause if a system becomes unstable, sensitive data is unexpectedly exposed, a target is found outside scope, the owner requests a stop, or an action may cause production impact. Preserve minimal evidence, notify the designated contact, and document the event.

Ethical boundary

A reachable service is not automatically an authorized target. Do not perform destructive testing, denial-of-service, credential spraying, persistence, or data exfiltration unless specifically authorized and safely controlled.

5. Methodology

Phase	Activities	Evidence / output
1. Plan	Authorization, scope, contacts, exclusions, baseline	Signed scope and test plan
2. Discover	Review supplied architecture and scoped attack surface	Asset inventory and observations
3. Assess	Configuration, authentication, dependency, and application checks	Candidate findings
4. Validate	Minimal, non-destructive reproduction; check prerequisites	Sanitized proof and confidence
5. Rate	CVSS v3.1 vector plus business context	Scoring rationale
6. Report	Executive summary, detailed findings, action plan	Draft report and register
7. Remediate	Assign owner, due date, and change plan	Remediation record
8. Retest	Verify fix and relevant regressions	Retest evidence and closure decision

Quality controls

• Separate confirmed facts from assumptions and unverified indicators.

• Record tool versions, time zone, and assessment limitations.

• Use test accounts and minimal proof; avoid collecting unnecessary sensitive data.

• Validate findings manually before assigning severity.

• Review the report with the technical owner for accuracy without allowing unsupported suppression.

This capstone package provides templates and report-generation scripts; it does not perform an automated scan. The example findings are for learning the reporting workflow.

6. Limitations, Assumptions & Confidence

Limitations

• No live target was assessed for this sample report.

• All assets and evidence descriptions are placeholders.

• The included CVSS scores and vectors are illustrative and must be independently validated before reuse.

• No source code, production configuration, logs, or network traffic was supplied.

• The report cannot determine whether compensating controls exist in a real environment.

Assumptions for the sample

The findings are presented as plausible reporting examples only. They do not establish exploitability or prove that any named or placeholder application has the stated weakness.

Confidence model for a real assessment

Confidence	Definition	Reporting approach
High	Repeatable evidence and clear affected component	State reproduction conditions and evidence IDs
Medium	Strong indicator but one condition remains unverified	Describe uncertainty and next validation step
Low	Heuristic or incomplete signal	Do not present as confirmed vulnerability; investigate further

Residual uncertainty

A point-in-time assessment cannot guarantee absence of vulnerabilities. Coverage depends on scope, access level, time, configuration, testing depth, and environmental changes.

7. Overall Risk Posture

The sample risk profile is intentionally small and designed to demonstrate prioritization. A real executive risk posture should consider asset criticality, internet exposure, sensitive data, exploit maturity, control effectiveness, and the business impact of downtime.

Finding ID	Title	Severity	CVSS example	Owner	Target
VAPT-002	Insufficient login throttling	High	7.1*	Identity Team	T+7 days
VAPT-001	Missing security headers	Medium	5.3*	Application Team	T+14 days
VAPT-003	Verbose error responses	Low	3.1*	Backend Team	T+30 days

*Illustrative values only. Confirm the vector and score with FIRST's official CVSS v3.1 calculator and document business-specific adjustments separately.

Risk interpretation

The High example should be validated first because authentication abuse may affect account security. Medium hardening should be scheduled soon after, while the Low example can generally follow the normal engineering process unless exposed details materially increase risk in the actual environment.

Management actions

• Confirm owners and service-level targets.

• Review whether any finding affects regulated data or critical business services.

• Track overdue items and formally document exceptions.

• Request retest evidence for all remediated findings.

8. Risk Matrix & Remediation Timeline

Likelihood / Impact	Low	Moderate	High	Severe
Almost certain	Medium	High	Critical	Critical
Likely	Low/Medium	High	Critical	Critical
Possible	Low	Medium	High	Critical
Unlikely	Low	Low/Medium	Medium	High

Illustrative remediation timeline

Priority	Action	Target	Exit criterion
P1	Validate and strengthen authentication throttling	7 days	Controlled test confirms limits, alerting, and safe recovery
P2	Deploy reviewed security headers	14 days	Header policy verified in staging and production
P3	Sanitize client-facing API errors	30 days	Production responses omit stack traces and secrets

Escalation

If a High or Critical finding cannot be fixed by the target date, the owner should document compensating controls, a risk acceptance decision, approver, expiry date, and interim monitoring. Risk acceptance is a business decision and should not be recorded as a technical fix.

9. Finding VAPT-002 — Insufficient Login Throttling

Severity: High (illustrative) **CVSS v3.1:** 7.1 (illustrative; validate vector)

Asset: app.example.test/login (placeholder) **Status:** Open

Description

The example design-review item represents a login flow where effective throttling and abuse detection have not yet been evidenced. This is not a confirmed issue on a live system. Validation should be performed only with a dedicated test account and within approved request limits.

Potential impact

If no compensating controls exist, repeated authentication attempts may increase the chance of account compromise and create operational burden. Actual impact depends on password policy, MFA coverage, detection, account recovery controls, and external identity protections.

Recommended remediation

• Implement server-side adaptive rate limits by account and source, avoiding easy bypass through trivial identifier changes.

• Require MFA for privileged accounts and sensitive actions.

• Use generic authentication and recovery responses to reduce account enumeration.

• Alert on unusual failure rates while avoiding logging passwords or tokens.

• Test rate-limit behavior and account recovery using controlled test accounts.

Retest criteria

A tester should verify that defined thresholds are enforced, repeated attempts are slowed or challenged, alerts are generated, recovery remains usable, and legitimate users are not unnecessarily locked out. Record sanitized timestamps and outcomes.

10. Finding VAPT-001 — Missing Security Headers

Severity: Medium (illustrative) **CVSS v3.1:** 5.3 (illustrative; validate vector)

Asset: app.example.test (placeholder) **Status:** Open

Description

The example observation concerns inconsistent browser security headers. Header absence alone does not always establish exploitability; review the application architecture and related weaknesses before final severity assignment.

Potential impact

An appropriately designed Content Security Policy can reduce the impact of some content-injection scenarios. Frame restrictions can reduce clickjacking exposure, while MIME-sniffing and referrer controls can improve browser-side defense-in-depth.

Recommended remediation

• Inventory scripts, styles, APIs, frame use, and third-party origins.

• Introduce a suitable Content-Security-Policy, using report-only mode during rollout when appropriate.

• Set X-Content-Type-Options: nosniff and an appropriate Referrer-Policy.

• Use frame-ancestors or an appropriate framing control.

• Test all supported browsers and monitor application compatibility.

Retest criteria

Capture sanitized response headers from the approved environment, verify the expected directives on relevant routes, and confirm the policy does not break required workflows.

11. Finding VAPT-003 — Verbose Error Responses

Severity: Low (illustrative) **CVSS v3.1:** 3.1 (illustrative; validate vector)

Asset: app.example.test/api (placeholder) **Status:** Open

Description

The sample finding represents an API that may return implementation detail beyond what a client requires. Confirm whether the response contains stack traces, filesystem paths, internal queries, environment values, or sensitive identifiers before treating it as a vulnerability.

Potential impact

Excessive diagnostic detail can help an attacker understand the implementation and plan further attempts. The impact is usually context-dependent and may be low if no sensitive detail is exposed.

Recommended remediation

• Disable debug output in production and configure generic error responses.

• Write diagnostic detail only to access-controlled server logs.

• Use a correlation ID so operators can investigate without exposing internals.

• Redact secrets and personal information from logs.

• Add regression tests for error paths and unexpected input.

Retest criteria

Trigger representative safe error conditions in a controlled environment. Verify that clients receive a stable error code and correlation ID, while sensitive implementation detail remains only in protected logs.

12. OWASP Top 10 Mapping

Finding	Primary mapping	Why it may fit	Validation caveat
VAPT-001	A05:2021 Security Misconfiguration	Security-related browser headers are configuration controls	Assess context and related exploitable weaknesses
VAPT-002	A07:2021 Identification and Authentication Failures	Authentication abuse controls may be insufficient	Verify actual controls and attack prerequisites
VAPT-003	A05:2021 Security Misconfiguration	Production error handling may reveal unnecessary details	Confirm the exact exposed information

Mapping guidance

OWASP categories describe broad classes of application risk; they are not severity levels. Select the category that best represents the root cause. A symptom can map differently depending on the design flaw, and a finding may have secondary mappings.

Additional categories to consider in real engagements

• A01 Broken Access Control — authorization bypass, insecure object access, privilege boundaries.

• A02 Cryptographic Failures — inappropriate protection of sensitive data.

• A03 Injection — untrusted input interpreted as commands or queries.

• A06 Vulnerable and Outdated Components — confirmed affected dependencies.

• A09 Security Logging and Monitoring Failures — inadequate detection and response.

Use the OWASP Top 10 version required by the engagement or client. This sample uses the 2021 edition for consistency.

13. CVSS v3.1 Scoring & Business Risk

CVSS provides a standardized severity estimate based on defined technical metrics. A valid score requires a coherent vector and a defensible assessment of exploit conditions and impact.

Metric group	Metrics	Question to answer
Exploitability	AV, AC, PR, UI	How can the issue be reached and what conditions or privileges are required?
Scope	S	Does impact cross a security authority boundary?
Impact	C, I, A	What confidentiality, integrity, and availability impact is plausible?

Score bands

Critical: 9.0–10.0; High: 7.0–8.9; Medium: 4.0–6.9; Low: 0.1–3.9; None: 0.0.

Required scoring discipline

• Record the complete CVSS:3.1 vector alongside the numeric score.

• Use the official calculator and preserve the rationale for each metric.

• Do not treat the score as a probability or a direct estimate of financial loss.

• Document business context separately: asset criticality, exposure, data sensitivity, threat activity, and compensating controls.

• Re-score when material assumptions change.

The example vectors and scores in this report are illustrative placeholders and may not be mathematically consistent. Recalculate them before using them in a real engagement.

14. Remediation Plan & Ownership

ID	Action	Owner	Target	Evidence of completion
VAPT-002	Implement and verify login throttling and abuse alerts	Identity Team	7 days	Controlled retest and monitoring evidence
VAPT-001	Deploy reviewed browser security headers	Application Team	14 days	Response header capture and regression results
VAPT-003	Sanitize production API error messages	Backend Team	30 days	Safe error tests and sanitized response evidence

Developer / sysadmin handoff

• Create a tracked issue for each finding and include its ID.

• Link to sanitized evidence in an access-controlled location.

• Describe expected behavior and regression tests in acceptance criteria.

• Schedule deployment through normal change management.

• Ensure logs and alerts support validation without storing secrets.

Risk exception requirements

If a fix is deferred, record the business justification, compensating controls, accountable approver, expiry date, review cadence, and conditions that trigger reconsideration. An accepted risk should remain visible in reporting until the exception expires or the issue is fixed.

15. Retesting & Closure Criteria

Status	Meaning	Minimum evidence
Open	Finding remains unresolved or not yet verified	Original evidence and assigned owner
In Progress	Remediation is underway	Change/ticket reference and target date
Fixed	A fix has been implemented but may await independent verification	Developer test results and deployment reference
Closed	Retest confirms the issue is resolved	Retest date, steps, sanitized evidence, reviewer
Accepted Risk	Authorized business owner accepts residual risk	Approver, rationale, controls, expiry date

Retest procedure

• Reconfirm the asset and scope are still authorized.

• Repeat only the minimum test steps needed to verify the original issue.

• Check nearby regression risks and normal business workflows.

• Capture a timestamped, sanitized result and update the evidence register.

• Close only when the acceptance criteria are met; otherwise record partial or failed remediation.

Closure checklist

• [ ] Finding owner confirms change deployed.

• [ ] Independent retest completed.

• [ ] Evidence hash recorded where appropriate.

• [ ] Residual risk reviewed.

• [ ] Report register and dashboard updated.

16. Evidence Register, Glossary & References

Evidence ID	Finding	Artifact	Handling
EV-001	VAPT-001	Sanitized response headers	Example placeholder; replace with authorized capture
EV-002	VAPT-002	Authentication test notes	Use test account and approved request limits
EV-003	VAPT-003	Redacted API error response	Remove tokens, personal data, and internal secrets

Evidence integrity

Use SHA-256 to detect accidental file changes after collection. A matching hash supports integrity checking but does not prove who created the file, when it was created, or whether the original observation is accurate. Maintain custody and access records for sensitive evidence.

Glossary

Term	Meaning
VAPT	Vulnerability Assessment and Penetration Testing
CVSS	Common Vulnerability Scoring System
OWASP	Open Worldwide Application Security Project
PoC	Proof of Concept; use minimal and non-destructive proof
Retest	Follow-up validation of remediation
Risk acceptance	Formal business decision to retain residual risk

References

• FIRST — Common Vulnerability Scoring System v3.1: https://www.first.org/cvss/v3.1/specification-document

• FIRST — CVSS Calculator: https://www.first.org/cvss/calculator/3.1

• OWASP Top 10:2021: https://owasp.org/Top10/

• OWASP Authentication Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

• OWASP Secure Headers Project: https://owasp.org/www-project-secure-headers/

End of sample report. Replace placeholders, validate scoring, and obtain technical and executive review before distributing a real report.